

Analisis kebutuhan keamanan, CIA Triad, threat modeling

Program Studi Informatika | Semester 7 | 2 SKS

Mata Kuliah: Strategi Keamanan Perangkat Lunak – Pertemuan 2

Dosen : Asep Id Hadiana, Ph.D.



Capaian Pembelajaran Tujuan Pertemuan (CPL-TP)

1

Memahami CIA Triad

Memahami dan membedakan komponen **CIA triad** beserta contoh pelanggaranannya dalam konteks sistem informasi

2

Analisis Threat Model

Menganalisis aset, aktor, dan ancaman untuk menyusun **threat model** sederhana pada sistem perangkat lunak

3

Penerapan Security Requirements

Menerapkan **security requirements** awal untuk studi kasus proyek mini dalam pengembangan perangkat lunak

4

Evaluasi Prioritas Risiko

Mengevaluasi prioritas risiko ($\text{likelihood} \times \text{impact}$) dan mengusulkan kontrol mitigasi tingkat tinggi



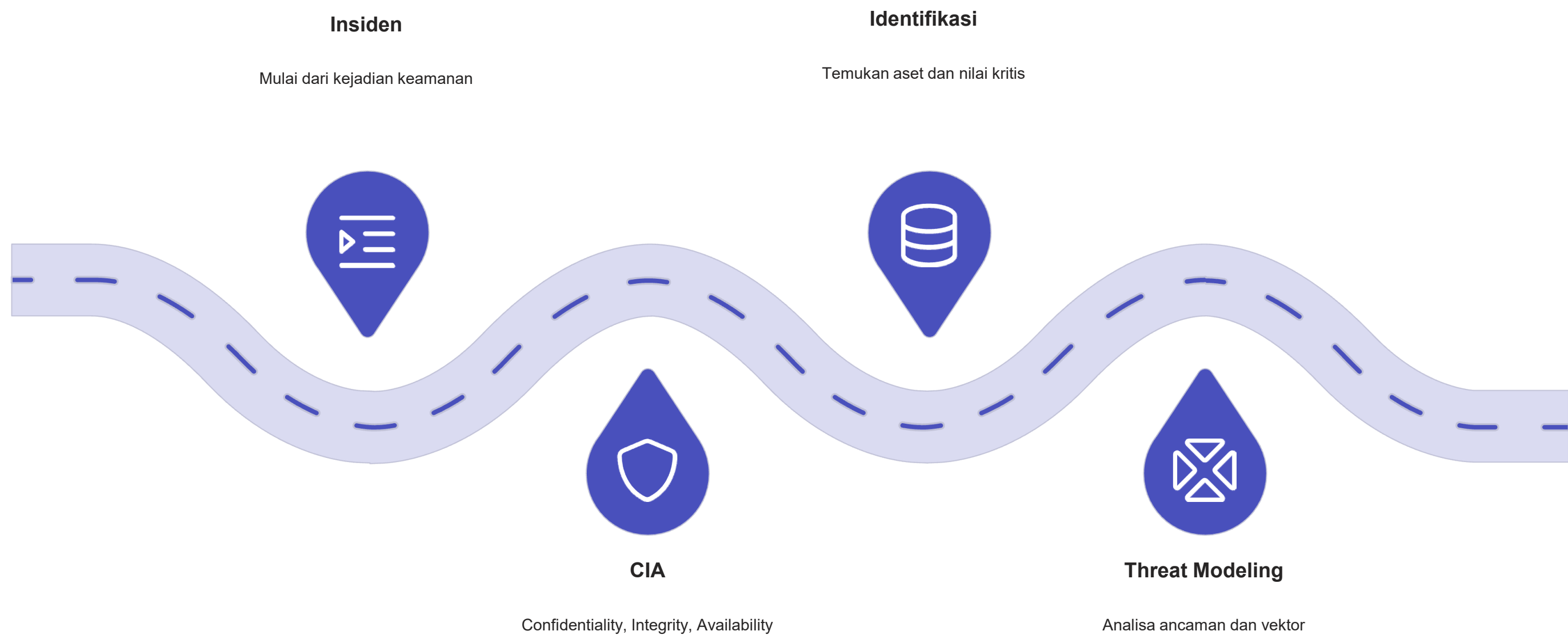
Hook: Insiden Keamanan di Sekitar Kita

"Kebocoran NIK 279 juta penduduk Indonesia (Confidentiality), perubahan nilai mahasiswa tanpa otorisasi (Integrity), SIAKAD down saat periode KRS (Availability)"

Setiap hari, sistem informasi menghadapi berbagai ancaman keamanan. Dari kebocoran data pribadi hingga gangguan layanan, dampaknya dapat merugikan jutaan pengguna. Bagaimana kita dapat mencegah dan mengurangi risiko ini?

Pertemuan hari ini akan membekali Anda dengan pemahaman dasar tentang strategi keamanan perangkat lunak melalui pendekatan sistematis.

Peta Konsep & Prasyarat



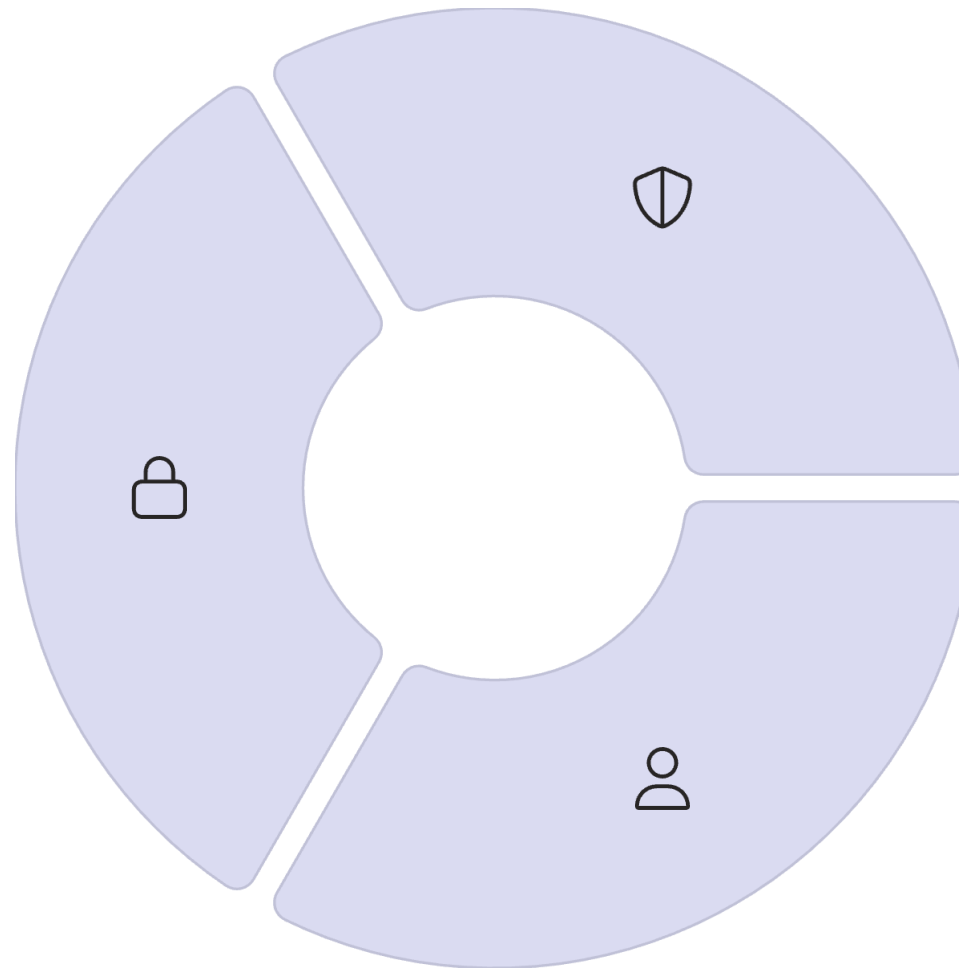
Prasyarat Pengetahuan

- Software Development Life Cycle (SDLC)
- Protokol HTTP/HTTPS

CIA Triad: Fondasi Keamanan Informasi

Confidentiality

Informasi hanya dapat diakses oleh pihak yang berwenang. Melindungi data dari akses yang tidak sah melalui enkripsi, kontrol akses, dan autentifikasi.



Integrity

Data tetap akurat, lengkap, dan tidak diubah tanpa otorisasi. Memastikan keaslian dan konsistensi informasi melalui digital signature dan hash functions.

Availability

Layanan dan informasi tersedia saat dibutuhkan oleh pengguna yang sah. Mencegah gangguan layanan melalui redundansi dan disaster recovery.

CIA: Contoh Kontekstual Indonesia

Insiden	Dampak	CIA Terdampak	Indikator Ukur
Kebocoran data mahasiswa dari portal akademik	Identitas tersebar, potensi penipuan	Confidentiality	Jumlah rekord bocor
Perubahan nilai tanpa otorisasi	Ketidakadilan akademik, kredibilitas institusi	Integrity	Frekuensi perubahan ilegal
Layanan ujian online down (DoS)	Gangguan proses evaluasi, kerugian waktu	Availability	Downtime duration

Contoh-contoh ini menunjukkan bagaimana setiap komponen CIA memiliki dampak nyata terhadap operasional institusi pendidikan dan kehidupan mahasiswa.

CIA: Common Pitfalls

✗ Mengira Enkripsi Menyelesaikan Semua

HTTPS hanya melindungi data in-transit, tidak menjamin availability atau authorization yang tepat

✗ Mengabaikan Kapasitas dan Backup

Fokus berlebihan pada confidentiality sambil melupakan disaster recovery dan business continuity

✗ One-Size-Fits-All Security

Menggunakan satu kontrol keamanan untuk mengatasi semua jenis risiko tanpa analisis mendalam

📄 **Solusi:** Terapkan defense-in-depth, lakukan uji beban rutin, dan drill restore procedure secara berkala

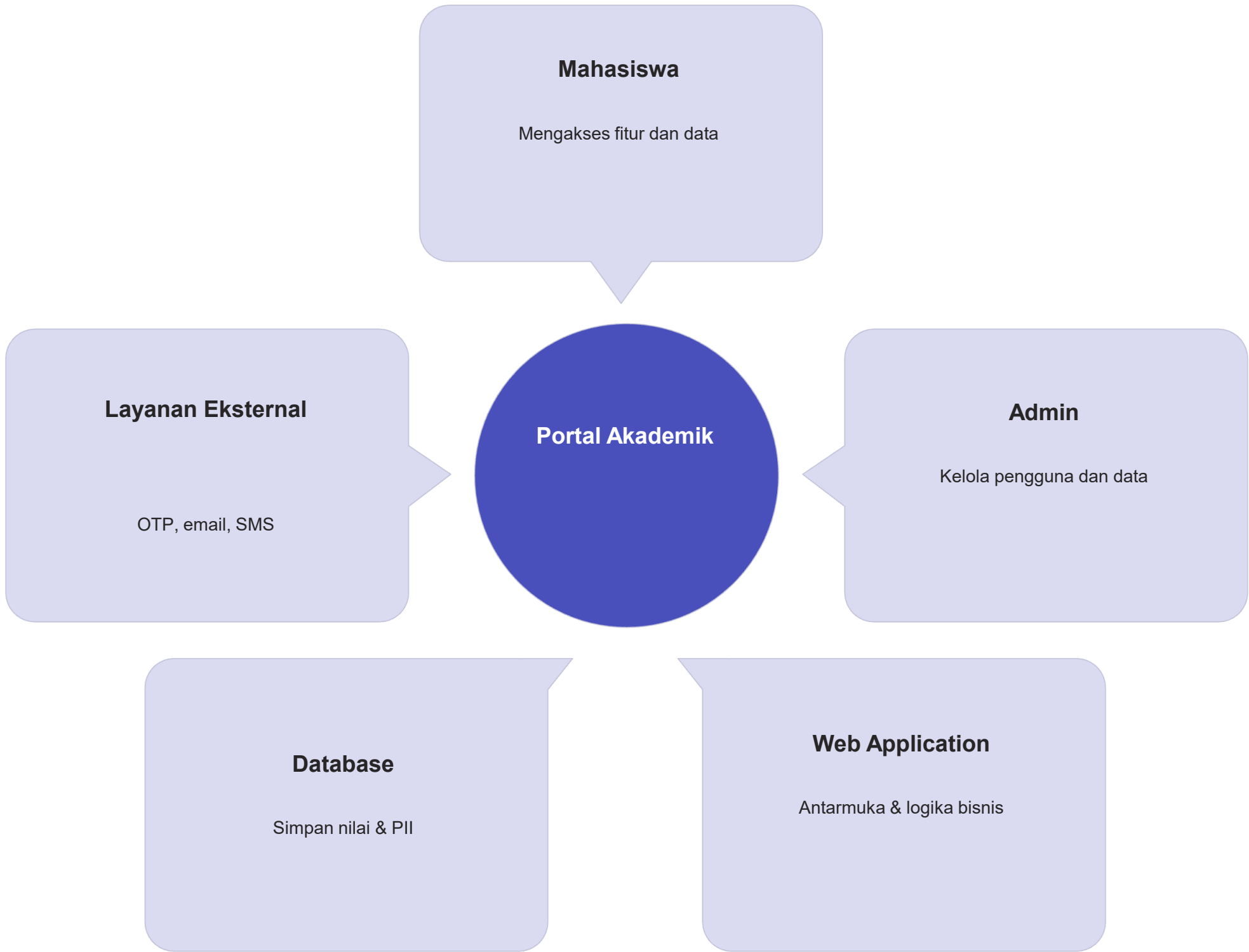
Threat Modeling: Alur 5 Langkah

01	02	03
Scope & Aset	Aktor & Antarmuka	Skenario Ancaman (STRIDE)
Tentukan batasan sistem dan identifikasi aset kritis yang perlu dilindungi	Petakan semua entitas yang berinteraksi dengan sistem, internal maupun eksternal	Identifikasi potensi ancaman menggunakan framework STRIDE secara sistematis
04	05	
Penilaian Risiko (L×I)	Kontrol Awal	
Evaluasi tingkat kemungkinan dan dampak untuk memprioritaskan penanganan	Rumuskan security requirements dan rencana mitigasi berdasarkan prioritas risiko	

Batas sistem yang memisahkan komponen terpercaya dari yang tidak terpercaya, menentukan titik kontrol keamanan



Contoh Sistem: Portal Akademik

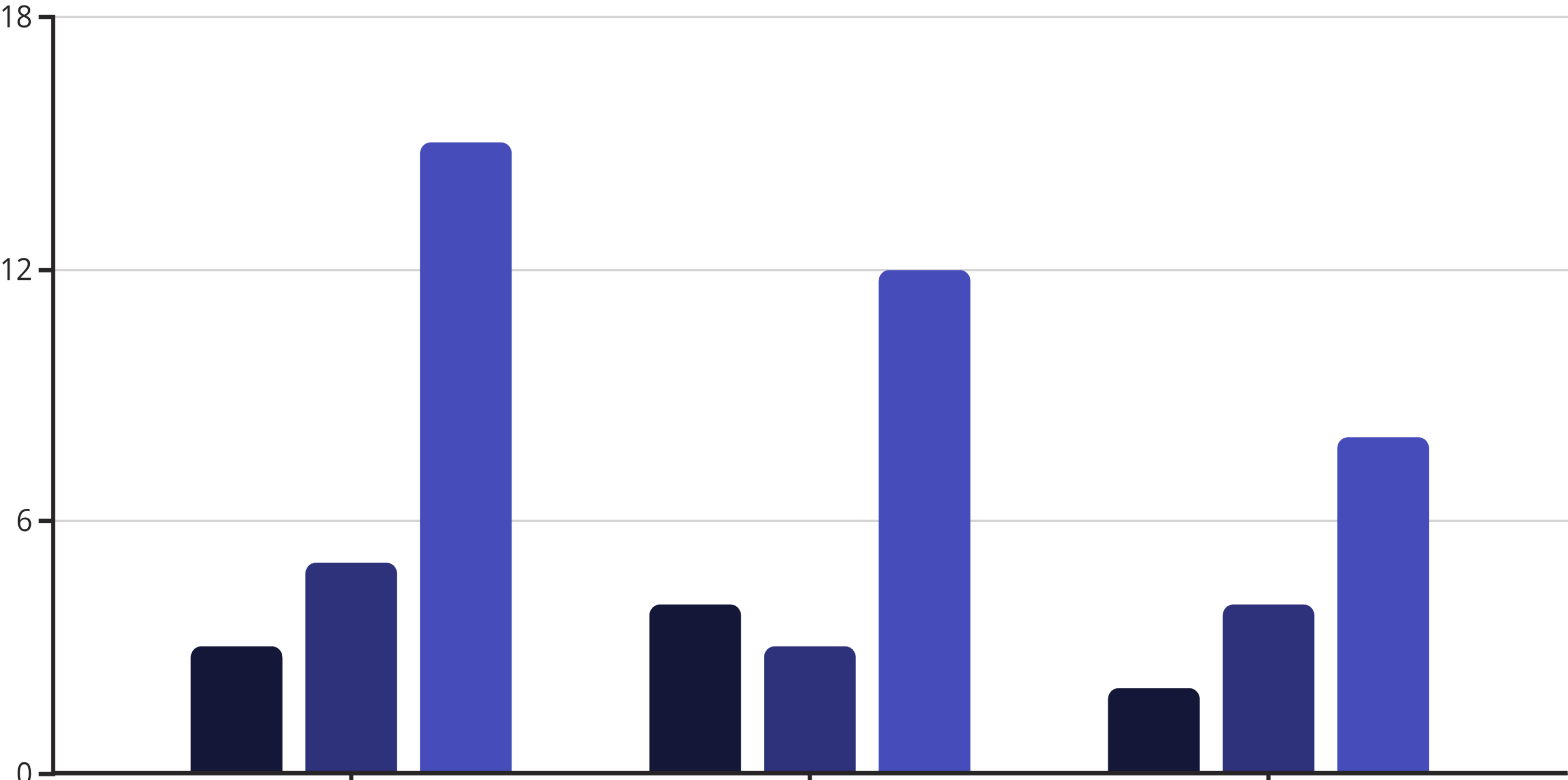


STRIDE Framework

Kategori	Contoh Skenario	CIA Terdampak	Kontrol Awal
Spoofing	Penyerang menyamar sebagai admin	Confidentiality	Multi-factor authentication
Tampering	Modifikasi nilai melalui IDOR	Integrity	Authorization checks
Repudiation	Penyangkalan perubahan data	Integrity	Audit logging
Info Disclosure	Akses data tanpa otorisasi	Confidentiality	Access control
Denial of Service	Overload server saat KRS	Availability	Rate limiting
Elevation of Privilege	User biasa akses fungsi admin	C, I, A	Role-based access

Penilaian Risiko: Likelihood × Impact

Penilaian risiko menggunakan skala 1-5 untuk mengukur kemungkinan (Likelihood) dan dampak (Impact) suatu ancaman.



Menurunkan Security Requirements

Security requirements harus dapat dilacak kembali ke ancaman spesifik dan dapat diimplementasikan secara teknis.

Ancaman	Security Requirement	Kontrol Kandidat
Credential stuffing pada login	Sistem harus menerapkan MFA untuk akses data nilai	TOTP, SMS OTP, biometric
Password cracking	Password disimpan dengan hash adaptif, minimum cost 12	bcrypt, scrypt, Argon2
Unauthorized data changes	Semua akses dan perubahan data dicatat dalam audit trail ≥12 bulan	Centralized logging, SIEM

 **Kunci:** Requirement harus high-level, vendor-neutral, dan dapat diverifikasi

Security Requirements: Pitfalls & Perbaikan

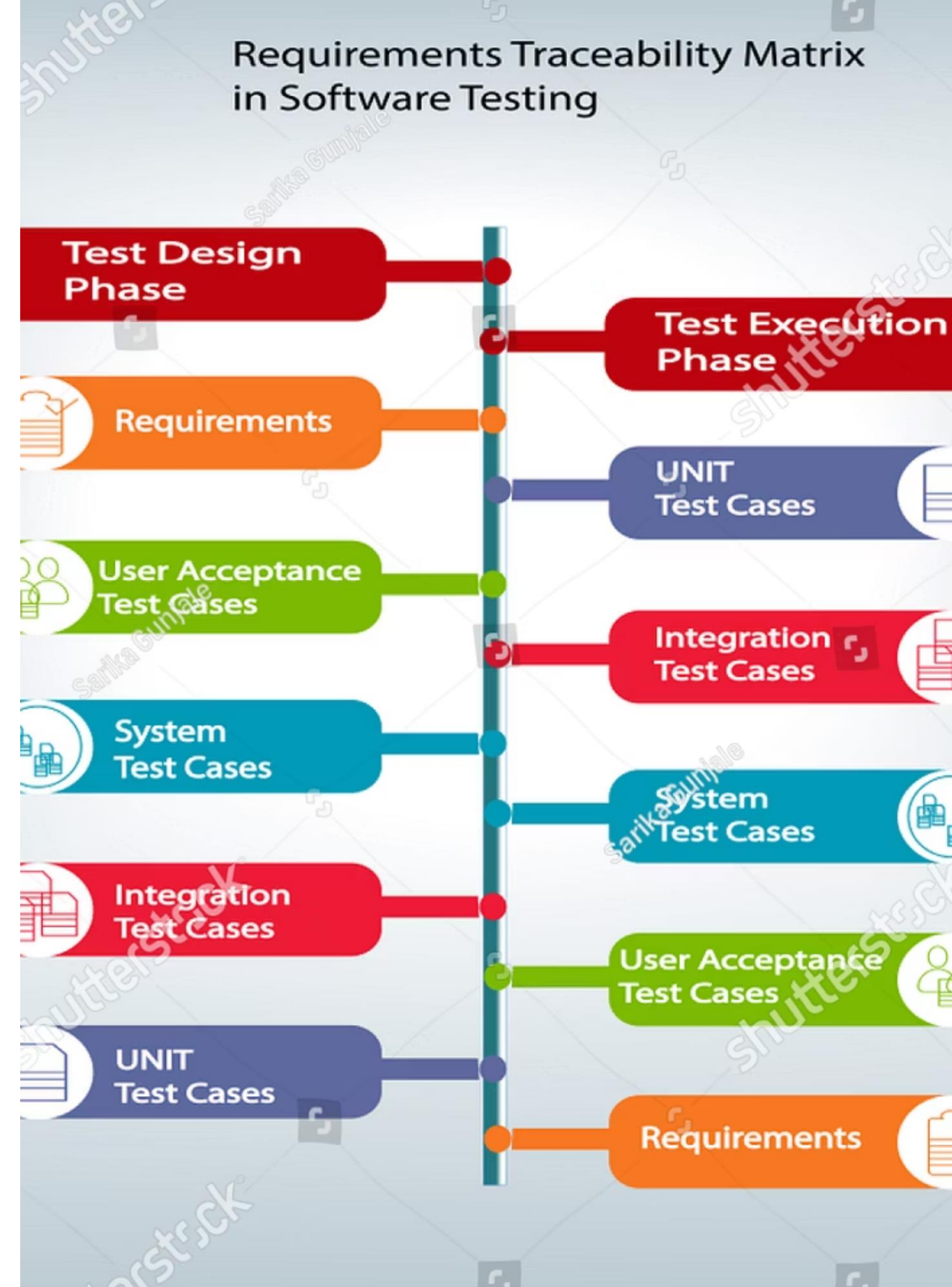
✗ Kesalahan Umum

- Terlalu teknis/terikat vendor sejak awal
- Tidak dapat dilacak ke ancaman spesifik
- Tidak dapat diverifikasi atau diuji
- Mengabaikan non-functional requirements

Perbaikan dimulai dari dokumentasi yang jelas dan proses review yang melibatkan stakeholder teknis dan bisnis.

✓ Best Practices

- Gunakan matriks traceability
- Review dengan tim lintas fungsi
- Definisikan kriteria acceptance
- Pertimbangkan usability dan performance





Aktivitas: Think-Pair-Share (8-10 menit)

01

Think (2 menit)

Secara individu, tuliskan 1 insiden keamanan yang pernah Anda alami atau ketahui, lalu tandai komponen CIA mana yang terdampak

02

Pair (3 menit)

Bergabung dengan partner, bandingkan dan diskusikan hasil analisis masing-masing.
Berikan feedback konstruktif

03

Share (3-5 menit)

2-3 pasangan mempresentasikan hasil diskusi ke seluruh kelas untuk pembelajaran bersama

Output: Daftar insiden terklasifikasi berdasarkan CIA triad

Rubrik (skala 1-4): Akurasi klasifikasi, kualitas argumentasi, efektivitas kolaborasi

Live Poll: Kuis Cepat (5 menit)

1 Soal CIA Triad

Insiden "server down saat ujian online" termasuk kategori CIA yang mana?

2 Soal STRIDE

Skenario "mahasiswa mengubah nilai teman melalui parameter manipulation" masuk kategori STRIDE apa?

3 Soal Security Control

Kontrol paling efektif untuk mencegah credential stuffing attack adalah?



Studi Kasus Kelompok (10 menit)

Skenario: Aplikasi Pendaftaran Wisuda Online dengan fitur login mahasiswa, upload berkas persyaratan, dan pembayaran biaya wisuda

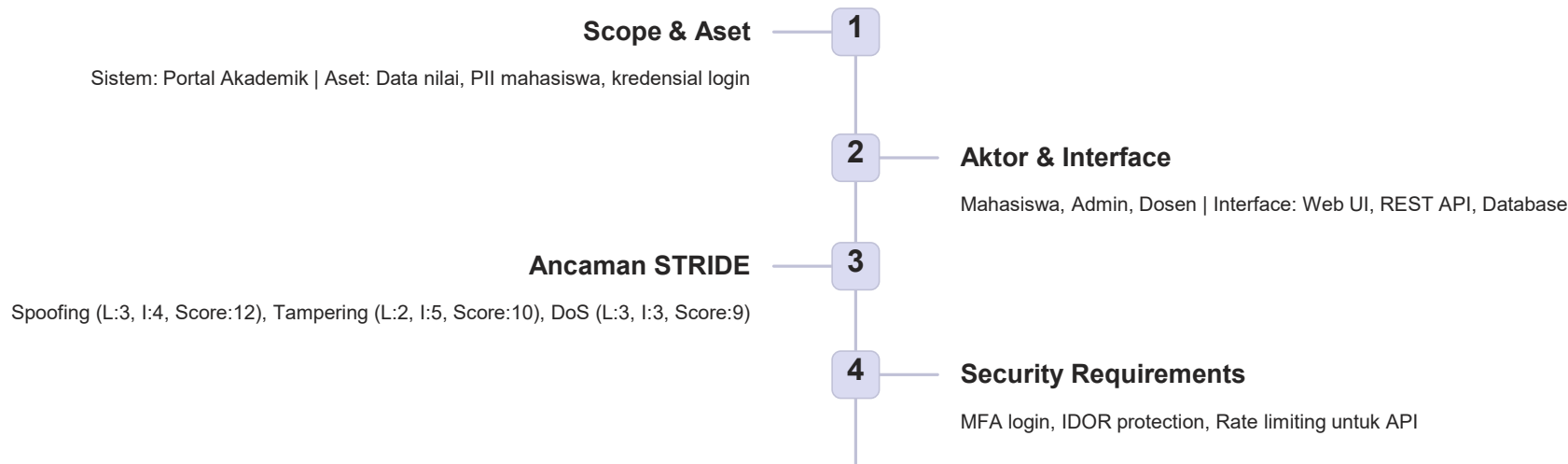
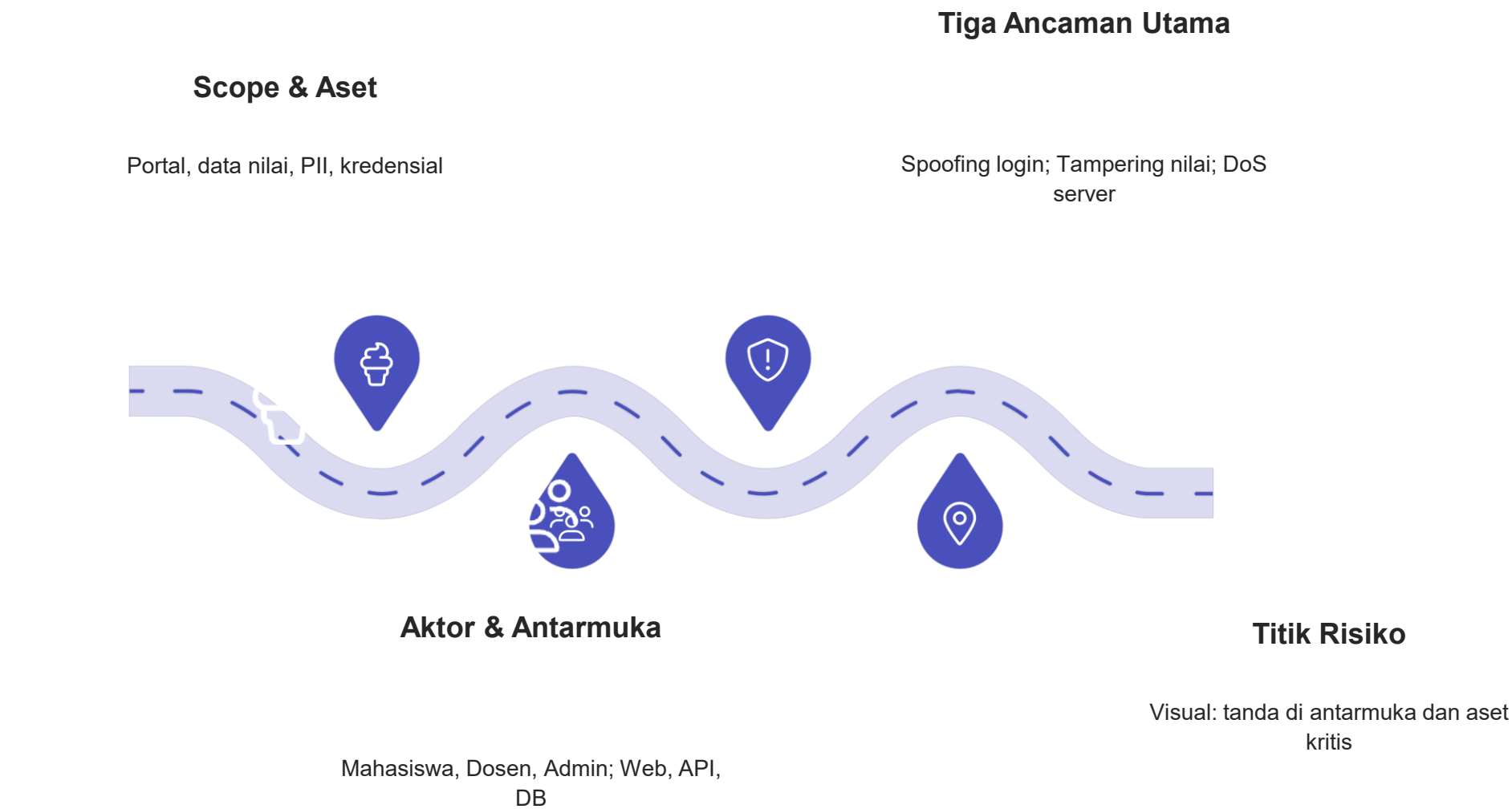
Tugas Kelompok

- Identifikasi 3 aset kritis sistem
- Tentukan 3 ancaman menggunakan STRIDE
- Hitung skor risiko ($L \times I$) untuk setiap ancaman
- Rumuskan 3 security requirements dasar

Rubrik (1-4): Relevansi aset (25%), ketepatan kategori ancaman (25%), prioritas risiko (25%), kejelasan requirements (25%)



Worked Example: Portal Akademik



Mini-Kuis: Evaluasi Pemahaman

1 Multiple Choice

Mana yang **bukan** komponen CIA? a) Confidentiality b) Integrity c) Availability d) Authenticity

2 True/False

HTTPS otomatis menjamin **Availability** sistem aplikasi web

3 Short Answer

Berikan 1 contoh konkret **Tampering** pada sistem informasi akademik

4 Multiple Choice

Kontrol awal paling tepat untuk brute-force login? a) CSP b) MFA c) Content-Encoding d) Lazy-load

5 Short Answer

Tulis 1 **security requirement** terkait audit trail untuk sistem informasi

2

Determine the scope of the assessment

6

Document and report findings

Tugas Mandiri (Opsional)

01

Pilih Aplikasi

Tentukan satu aplikasi yang sering Anda gunakan (e-commerce, social media, e-learning, dll.)

03

Threat Modeling

Tentukan 3 ancaman menggunakan framework STRIDE, hitung skor risiko ($L \times I$)

Deliverable: Dokumen 1-2 halaman dengan analisis lengkap

Bobot Penilaian: Ketepatan analisis (30%), prioritas risiko (30%), keterkaitan requirements (30%), kerapian dokumen (10%)

02

Analisis Aset

Identifikasi 3 aset kritis yang perlu dilindungi dalam aplikasi tersebut

04

Security Requirements

Rumuskan 3 security requirements yang dapat dilacak ke ancaman yang diidentifikasi

Ringkasan: 5 Poin Kunci

CIA = Lensa Evaluasi

CIA Triad menyediakan kerangka sistematis untuk mengevaluasi dampak insiden keamanan pada sistem informasi

Threat Modeling = Narasi Sistematis

Proses terstruktur dari identifikasi ancaman hingga perumusan kontrol keamanan yang efektif

Risiko $L \times I$ untuk Prioritas

Penilaian likelihood $\times$ impact membantu memprioritaskan penanganan ancaman berdasarkan sumber daya yang tersedia

Requirements Harus Traceable

Security requirements yang baik dapat dilacak kembali ke ancaman spesifik dan dapat diverifikasi implementasinya

Input untuk Secure Design

Output hari ini menjadi foundation untuk mempelajari secure design principles di pertemuan berikutnya

What did you learn today?	I learned about the water cycle and how it works.
What was challenging for you today?	The most challenging part of the day was solving math problems with fractions.
What could you have done differently to make today better?	I could have asked more questions during class to clarify my understanding of the topics we were covering.
What was your favorite part of the day?	My favorite part of the day was participating in the science experiment and observing the different stages of the water cycle.
What goals do you have for tomorrow?	Tomorrow, I want to focus on improving my understanding of fractions and practice solving more problems.

REFLECTION SHEET TEMPLATE

Improve your learning process by using this template for insightful self-assessment and progress tracking.

Refleksi 1 Menit

Instruksi Refleksi: Tuliskan dalam 1-2 kalimat

1 Risiko Utama Proyek Mini Saya

Identifikasi satu risiko keamanan yang paling mungkin terjadi pada proyek pengembangan perangkat lunak yang sedang Anda kerjakan

1 Kontrol Awal yang Akan Diterapkan

Tentukan satu kontrol keamanan dasar yang dapat Anda implementasikan untuk mengurangi risiko tersebut

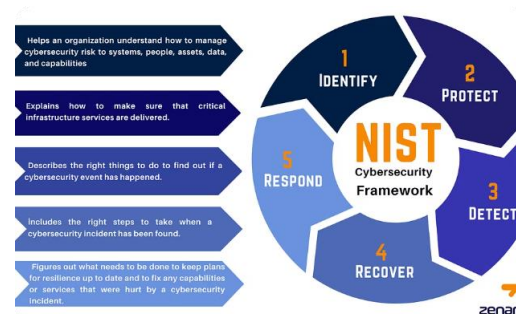
Pengumpulan: Scan QR code atau akses link Google Forms yang disediakan. Hasil refleksi akan digunakan sebagai bahan diskusi pertemuan berikutnya.

Referensi Primer & Standar



OWASP Resources

- OWASP Top 10 (edisi terbaru)
- OWASP Threat Modeling Cheat Sheet
- OWASP Application Security Verification Standard (ASVS)



NIST Standards

- NIST SP 800-30 Rev.1 (Risk Assessment)
- NIST Cybersecurity Framework
- NIST SP 800-53 (Security Controls)

International Standards

- ISO/IEC 27001:2022 (ISMS)
- ISO/IEC 27002:2022 (Security Controls)
- Microsoft SDL - STRIDE Overview

Terima Kasih & Persiapan Pertemuan Berikutnya

Hari Ini
CIA Triad, Threat Modeling, Risk Assessment, Security Requirements

Pertemuan 5
Security Testing & Verification



Pertemuan 3
Secure Design Principles & Architecture Patterns

Pertemuan 4
Secure Coding Practices & Implementation

Persiapan Minggu Depan: Review konsep secure design patterns dan baca chapter 1-2 dari referensi yang diberikan. Siapkan pertanyaan tentang implementasi security controls dalam proyek Anda.

Selamat belajar dan tetap jaga keamanan sistem informasi!